GroVastra Social Features Technical Handoff

Instagram analytics • Comment automation • Link in bio

Version 1.0 | 13 October 2026 | Recipient: GroVastra engineering team

1 Implementation mandate

Build an Instagram connection that imports a shop's content and social performance metrics, supports one requested private reply to a keyword comment, and supplies a live link-in-bio page. The owner must be able to inspect account performance and individual reel performance without any order, payment or CRM integration.

This release excludes per-reel revenue and all sales attribution. Do not add revenue, orders, payments, ROAS, customer matching or conversion-to-sale fields to its APIs, dashboards, exports or acceptance criteria.

Release scope

Deliverable	Required outcome
Social analytics	Account overview and per-reel views, reach, likes, comments, saves, shares and interactions; availability and freshness shown explicitly.
Comment automation	A configured keyword on a selected post or reel triggers one permitted Instagram private reply with an approved link. Optional public acknowledgement.
Link in bio	One mobile page per shop with current catalog items, imported reels and selected contact links. Track page interactions only.
Operations	Tenant isolation, permission handling, sync health, send logs, deletion handling and release tests.

Platform boundary

Instagram is the first provider. Use extensible provider fields, but do not implement Facebook Page analytics, LinkedIn APIs, YouTube analytics, publishing, paid-ad reporting, Stories reporting or a conversational chatbot in this release. The bio page can be linked from any profile. WhatsApp is an outgoing link only; no WhatsApp API is required.

How to use this handoff

Sections 2–8 define behavior and implementation decisions. Sections 9–12 specify data, APIs and controls. Section 13 gives delivery checkpoints and acceptance tests; Section 14 lists primary sources. MUST identifies a release requirement. SHOULD identifies a recommended implementation default. The names and routes below are proposed contracts for this build.

2 Architecture and integration boundaries

Implement this as an addendum to the planned GroVastra production architecture [L1–L3]. The architecture documents describe an AWS-first TypeScript platform. The current saree-sabha-demo is a separate family-selection prototype using Vinext and Cloudflare D1; do not assume it already provides the production social backend.

Application or module	Responsibility
api/modules/social	OAuth, account ownership, provider adapter, media import, metric reads and connection lifecycle.
api/modules/comment-automation	Rules, verified webhook ingestion, eligibility evaluation and reply audit records.
api/modules/links	Bio configuration, safe destinations, content mappings and first-party interaction events.
worker-jobs	Media and metrics sync, token maintenance, private replies, public acknowledgements and retention jobs.
web-owner	Connections, account overview, reels list/detail, automation rules/activity and bio preview.
web-public	Tenant-resolved /bio with server-rendered catalog and reel cards.
packages/core and db	Zod contracts, tenant-scoped repositories, indexes and schema migrations.

Data flow

Instagram OAuth -> socialAccounts -> media and metrics jobs
Instagram comments -> signed webhook -> durable event -> reply worker
Catalog + imported content -> public bio page -> interaction events
Metric snapshots + bio rollups + reply logs -> owner dashboard

Reuse the planned Express API, Mongoose repositories, DocumentDB compatibility checks, Redis/BullMQ queues, S3 media storage and CloudWatch monitoring. Use AWS KMS or the existing secret-management pattern for credentials. Preserve the mandatory transactional outbox for database writes that schedule side effects. Do not put Instagram send logic into the WhatsApp gateway.

Adapters and dependency boundaries

Define InstagramProvider operations for authorize, exchangeCode, refreshToken, getAccount, listMedia, getAccountMetrics, getMediaMetrics, subscribeComments, sendPrivateReply and replyToComment. Keep provider field names and error translation inside the adapter. Pin a supported Graph API version in configuration; current reference examples show v26.0 [S2, S3].

Catalog reads must use a narrow publicCatalog adapter. If production catalog integration is not available, ship a links-and-reels bio page and hide the live-stock section. Do not substitute static demo stock and describe it as live. Social analytics and keyword replies to approved collection links must still function without catalog, CRM, orders or payments.

3 Account connection and permission lifecycle

Use Instagram API with Instagram Login for professional Business or Creator accounts. The connected account must belong to the shop or be managed with its authorization. Personal accounts cannot supply the required professional insights [S1].

Permission	Use in this release
instagram_business_basic	Account identity and owned media import.
instagram_business_manage_insights	Account and media insights.
instagram_business_manage_comments	Comment webhooks, public replies and the initial comment-triggered private reply.
instagram_business_manage_messages	Not requested by this MVP. Add only with a later inbound DM or continuing conversation feature.

The initial private reply uses the comment permission; do not request broad messaging or publishing permissions merely because the feature sends a private reply [S4, S5]. The insights-specific documentation explicitly lists the insights permission; validate the chosen permissions in the live App Dashboard during the integration spike [S1–S3].

Connection sequence

- An authorized owner selects Connect Instagram. The backend creates a one-time, cryptographically random OAuth state bound to the user, tenant and allowlisted return URL, with a ten-minute expiry.
- The callback verifies state and exchanges the code server-side. Fetch account identity from Meta; never accept a browser-supplied provider account ID as proof of ownership.
- Store granted scopes and encrypted token reference, validate required capabilities, subscribe the account to comment events, and enqueue media import and metrics backfill.
- Show connected username, available capabilities, last successful sync and reconnect status. Declined insights permissions must disable analytics without fabricating zero data.
- Reject an account already attached to a different tenant with ACCOUNT_ALREADY_CONNECTED. A transfer requires an explicit ownership workflow, not a silent reassignment.

Lifecycle and operational behavior

States: connecting, connected, partial_permissions, reconnect_required, disconnected and deleting. Serialize token refresh per account; use provider-returned expiry and documented refresh eligibility. Never assume a refresh token or a fixed token lifetime. A daily maintenance job should refresh eligible credentials before expiry and surface failures.

Disconnect must stop queued sends and syncs immediately, unsubscribe/revoke where supported, and remove credentials. Explain the subsequent data-deletion policy in the owner UI. On callback errors, invalid state or revoked access, preserve an auditable status without logging tokens or authorization codes.

GroVastra serves multiple businesses, so App Review and Advanced Access are release dependencies. Testing with a registered development account is not evidence that unrelated customer accounts can connect [S6].

4 Link in bio requirements

Serve /bio on each shop's configured storefront host, for example padmavati.grovastra.store/bio. Resolve the tenant from the validated host/domain mapping. The owner copies the link into a social profile. A source tag such as utm_source=instagram&utm_medium=bio may be added, but it is a source label, not proof of the viewer's prior reel activity.

Public page

- Render shop name, approved logo/theme, short description, verified identity link and a visible WhatsApp contact action. Use the existing language pack; support English and Telugu where the parent application already supports them.
- Show the latest 12 publishable available catalog pieces when the catalog adapter is connected. Read current price and state from that adapter; a sold piece must stop appearing as available within the existing ten-second storefront propagation target.
- Show recent imported reels with thumbnail, publication date, Instagram permalink and linked product or collection destination. A reel with no product mapping opens its approved permalink or configured collection.
- Keep the normal page automatic: newest pieces and newest imported reels first. Allow minimal owner settings for visibility, description and approved fixed links; do not require daily editing.
- Provide responsive cards, meaningful image text, keyboard access, readable contrast, complete link previews and lazy-loaded thumbnails. Do not autoplay every reel or embed full Instagram players on initial load.
- If Instagram is disconnected or unavailable, keep the page shell and independent catalog working. Hide unusable Instagram media or show a local approved placeholder. Never expose connection diagnostics publicly.

Page events and link safety

Record page_view, reel_selection, product_selection and outbound_whatsapp_click. Optional fixed-link clicks use outbound_link_click. These events measure interactions only. A WhatsApp click is not a message, lead or customer. A selected reel is not proof that its Instagram view caused a visit.

Use a server-issued public-page context to validate the tenant and permitted content IDs. Dedupe eventId; apply bot filtering and rate limits. Record only allowlisted source tags. Drop arbitrary query strings, full referrers, phone numbers, comment text and raw IP addresses from analytics storage. Use an ephemeral session identifier only where the deployed privacy configuration permits it; otherwise show event counts rather than unique visitors.

Destinations are stored server-side as same-tenant product/collection IDs or reviewed HTTPS links. Reject javascript/data schemes, open redirect targets and unapproved hosts. Preview the resolved destination before activation. Use a tracked GroVastra redirect for WhatsApp clicks, and resolve the shop's current number at click time. This route must not invoke the older lead-creation behavior of /m/.

Performance acceptance

Target LCP below 2.5 seconds on the agreed mid-range mobile test profile, no layout-breaking overflow at 360 px, and functional links when event collection fails. Cache the public projection; stock changes invalidate it. Never cache personal OAuth or owner dashboard responses as public content.

5 Comment automation behavior

MVP trigger: a configured keyword in a new top-level comment on a selected owned Instagram post or reel. The seller must explicitly enable each rule. Suggested caption: “Comment PRICE and we will DM the details.” The rule is an instruction to fulfil that request; it does not enroll the commenter in ongoing marketing.

Rule configuration

Field	Contract
Target	One connected account and one owned media ID. Account-wide rules and Live comments are excluded from MVP.
Keywords	A bounded list such as PRICE, DETAILS or GV1041. Use Unicode NFKC and case folding; use exact normalized matching by default, with surrounding whitespace and punctuation trimmed.
Response	Owner-approved plain-text template plus one server-resolved destination. Render only allowlisted variables; never execute instructions from comments.
Destination	Mapped product, collection or approved shop link. A rule can work without a product mapping by using a collection link.
Public acknowledgement	Off by default. If enabled, send a short acknowledgement only after the private-reply API accepts the message.
Conflict rule	One active matching rule per media/keyword. Reject overlaps. Keep an immutable revision for every rule change.

Meta limits that the worker must enforce

Send at most one initial private reply per comment, within seven days of comment creation. Live replies have a different window and are excluded here. A further automated DM requires a response from the recipient and must fall within the allowed 24-hour response window; this release implements no follow-up sequence [S4]. A URL click alone must not be treated as such a response.

Provider calls

```
POST https://graph.instagram.com/{version}/{igAccountId}/messages
Authorization: Bearer <server-side token>
{"recipient":{"comment_id":"<commentId>"},
 "message":{"text":"Here are the details: <approved tracked link>"}}

# Optional public reply, only after private API acceptance
POST https://graph.instagram.com/{version}/{commentId}/replies
{"message":"I have sent the details in a private message."}
```

The account token and identifiers come from the authorized server connection, not the browser. Private replies can arrive in the recipient’s Requests folder. Record an accepted provider response as sent/API accepted; do not call it delivered or read without separate provider evidence [S4].

Product details must come from the catalog at send time. Do not reserve stock on a comment. If the product has sold, send the approved sold-state wording and a collection link. Do not place personal details or negotiated prices in a public reply.

6 Webhooks and reliable reply processing

Ingestion

Expose GET /hooks/instagram for Meta verification and POST /hooks/instagram for events. Verify the challenge token on GET. On POST, verify X-Hub-Signature-256 against the raw request bytes with the app secret before parsing or processing. Reject invalid signatures. Resolve tenant and connection from the registered recipient account ID, never from an event-supplied tenantId.

Persist a minimal, deduplicated event and an outbox record before returning HTTP 200. Return a retryable server error if durable storage fails. A verified duplicate is a successful acknowledgement. Unsupported events may be safely acknowledged without a send. Keep the public endpoint bounded by payload size and rate limits.

Worker algorithm

- Acquire the unique private-reply record for tenant, account and provider comment ID. This uniqueness spans rule revisions and all retry attempts.
- Reject self-comments, unsupported media, nested replies, disabled or deleted rules, mismatched account ownership and absent keyword matches. Import/backfill jobs must never trigger replies to historical comments.
- Read current permissions, connection state, rule state and comment creation time. Require commentCreatedAt >= enabledAt; enabledAt resets on each activation. Do not use delivery time as creation time. If creation time cannot be verified, suppress the send. Recheck expiry immediately before dispatch.
- Resolve the approved destination and live product state. Apply one private reply per commenter per media in a rolling 24-hour period as an additional GroVastra cooldown; keep it separate from Meta's per-comment limit.
- Create a durable dispatch claim, set sending, and call Meta. Persist the returned message ID before any public acknowledgement is scheduled.
- Recheck disconnect and pause state at the final send boundary. An already in-flight provider request may finish after a pause; show that limitation and retain its audit record.

States and retries

```
received -> queued -> sending -> sent
            -> suppressed | expired | failed
            -> unknown_outcome
```

A timeout after dispatch may mean Meta accepted the message. Mark unknown_outcome and do not automatically resend it, even after a worker restart. Reconcile using provider evidence where available; otherwise leave it for operational review. An ambiguous state is not a failed send. Do not promise exactly-once delivery across a network boundary.

Retry only explicit, retryable failures known not to have accepted a send. Use bounded exponential backoff with jitter and provider retry guidance. Stop retries before the eligibility deadline. Authentication failures require reconnection; rate limits defer work; permanent permission or media errors suppress the action and show a reason.

For public acknowledgements, use a separate dedupe key per comment/action. A public acknowledgement failure must never retrigger the private DM. Maintain a tenant pause switch and a global incident switch. This workflow does not read or send WhatsApp messages.

7 Social analytics screens and reel metrics

Add Social within the owner app's Numbers area. Provide account selection, 7-day and 30-day account ranges, custom ranges within supported limits, a per-reel list, reel detail, and a CSV export. Show connected account, data coverage and last successful sync on every analytics screen.

Per reel metrics

Display metric	Provider metric	Interpretation
Views	views	Plays on Instagram; not unique people.
Reach	reach	Unique Instagram accounts reached by that reel; use provider value.
Likes	likes	Current likes on the reel.
Comments	comments	Provider comment total; separate from qualifying automation comments.
Saves	saved	Media-level key is saved, not saves.
Shares	shares	Provider share count for the reel.
Interactions	total_interactions	Provider-defined combined interaction count. Keep its definition/version.
Reposts	reposts	Optional enhancement after capability validation.
Watch time and skip rate	ig_reels_avg_watch_time; ig_reels_video_view_total_time; reels_skip_rate	Optional detail metrics. Validate units, scale and eligibility with real responses before exposing them.

The first seven rows are the core per-reel dashboard. Fetch them through the owned media insights endpoint. Unsupported, delayed or withheld values remain unavailable; implementing the field does not guarantee Meta will return it for every account or media object [S2].

List and detail behavior

Each row shows thumbnail, caption excerpt, publish date, media link and current metrics. Sort by publish date, views, reach or interactions with deterministic ID tie-breaking and nulls last. Use cursor pagination. A date filter on this list means "Reels published during this period"; displayed numbers are latest lifetime totals, not necessarily activity within that period.

Detail shows the same totals with asOf timestamps, availability reasons and the optional observed snapshot history. Label that history "Observed totals since connection"; it cannot reconstruct engagement before GroVastra collected snapshots. Downloaded CSVs must include scope, period, availability and asOf, and defend against spreadsheet-formula injection in captions.

Metric boundaries

Current media docs list views, likes, comments and total_interactions as organic interaction metrics. The total_views, total_likes and total_comments variants include additional promoted/boosted/ad surfaces and require Facebook Login; these variants are outside this implementation [S2]. Do not label every account metric organic: some account metrics include ads by Meta's definition. Preserve that distinction in tooltips.

Do not expose impressions or legacy plays as substitutes for views. Do not promise per-reel profile visits or follows: the current reference does not list those as REELS metrics [S2].

8 Account metrics and synchronization

Account overview

Metric group	Provider mapping and behavior
Views and reach	views and reach from account insights for the requested interval. Preserve provider aggregation and paid-inclusion definitions.
Engagement	likes, comments, saves, shares and total_interactions; account saves differs from media saved.
Engaged accounts	accounts_engaged if supported; this is not the sum of likes/comments or unique bio visitors.
Followers	Current account follower total from the account profile when available. Optional follows_and_unfollows is an insights metric with eligibility limits; do not confuse it with the current total.
Profile actions	Optional profile_links_taps with provider descriptions. Do not label it GroVastra bio visits or assume it measures only website-link taps.

Fetch account totals from the provider for the selected range. Never sum daily reach and label it unique reach for a week/month; never sum reel reach into account reach. Where a provider cannot supply a requested unique total, return unavailable. Split long ranges only for additive metrics; suppress a deduplicated total if it cannot be requested as one supported query [S3].

Collection schedule and coverage

Job	Recommended initial schedule
Media discovery	At connection, then every 15 minutes; import 90 days initially with cursor-based pagination and resumable progress.
Reel metrics	Every 6 hours for media up to 30 days old; daily for 31–90 days; weekly for older imported reels. Allow a throttled owner refresh.
Account metrics	Daily fetches plus exact supported 7/30-day aggregate queries. Re-fetch the last 3 complete provider days for corrections. Throttle owner refresh to once per 15 minutes.
Backfill	Up to the last 90 available account days, subject to per-metric/provider limits. Store actual earliest coverage, not an assumed full history.
Token and cleanup	Daily maintenance; immediate disconnect handling; scheduled retention and deletion jobs.

For a missing custom interval, enqueue a deduplicated provider query and return pending with queryId. Poll stored query status; return unavailable if that exact unique aggregate is unsupported. Cache presets by their actual interval. Daily reach cannot generate these unique totals.

These schedules are engineering defaults, not rate-limit entitlements. Bound concurrency, respect provider headers and stagger jobs. Read dashboards from stored observations; do not fan out on page load. Meta may delay insights by up to 48 hours [S2, S3].

Normalization rules

Parse both values[] and total_value response shapes. Preserve provider name, definition, period, interval, breakdowns, API version and retrieval time. Request only compatible metric groups; one unsupported metric must not erase valid metrics. Empty data is null with a reason, not zero. A confirmed numeric zero remains zero.

Store timestamps in UTC; display event times in Asia/Kolkata. Preserve the provider's reporting-day boundaries and label them; do not silently rebucket daily aggregates into IST. Retain corrected values and observation timestamps. Do not sum successive lifetime snapshots or clamp negative corrections into invented growth.

9 Core data contracts

All owned records use internal ULID identifiers, tenantId and timestamps. Every repository query requires TenantContext. Provider IDs are opaque strings, not integers or global customer identities. The following contracts are new or extensions; they are not claims about already implemented collections.

socialAccounts

```
{ id, tenantId, provider: "instagram", providerAccountId, username,
  accountType, loginType: "instagram", tokenRef, tokenExpiresAt,
  grantedScopes: [], status, connectionGeneration,
  lastMediaSyncAt, lastMetricsSyncAt, lastErrorCode,
  capabilities: {}, coverage: {}, createdAt, updatedAt }
```

Keep tokenRef in protected storage and return no token fields to the client. Enforce a unique provider/account ownership record so one Instagram account cannot silently become connected to two tenants. Increment connectionGeneration on disconnect/reconnect; jobs with an old generation cannot send or write new data.

contentItems extension

```
{ id, tenantId, socialAccountId, provider: "instagram",
  providerMediaId, mediaType, mediaProductType, caption,
  permalink, thumbnailRef, thumbnailExpiresAt, publishedAt,
  importStatus, pieceIds: [], destinationRef, hiddenFromBio,
  lastSeenAt, deletedAt, createdAt, updatedAt }
```

Unique index: tenantId + socialAccountId + providerMediaId. Detect reels using provider media_product_type=REELS, not VIDEO alone. A caption is untrusted display text. Validate product mappings within the same tenant. Do not write social metrics into the legacy contentItems.stats object, which mixes clicks, orders and revenue [L2].

socialMetricObservations

```
{ id, tenantId, socialAccountId, contentId: null | "cnt_...",
  scope: "account" | "media", providerMetric, metricKey,
  value: number | null, unit, period, metricType,
  intervalStart, intervalEnd, breakdownKey, definitionVersion,
  apiVersion, providerDefinition, collectedAt, providerDataEndAt,
  availability, unavailableReason, collectionRunId }
```

availability is available, unavailable, unsupported or permission_missing. Read models set freshness to fresh or stale for a numeric value, and null when no numeric observation exists. Expose lastAttemptAt separately from asOf, which is null when no value was observed. Only use units verified by the provider adapter.

Define query identity as tenant/account/content/scope/providerMetric/definitionVersion/period/metricType/exact interval/breakdown. Use it for latest-value projections and cached queries; add collectionRunId to dedupe observations. Retries keep that run ID. A stale fallback must match this identity and retain its actual interval; never reuse a different rolling range as the requested range.

Maintain a versioned metric registry describing endpoint, compatible media types, request shape, unit, aggregation rules, paid inclusion and availability constraints. A capability test against the pinned API version must populate this registry before production rollout.

10 Automation and bio data contracts

Rules and reply records

```
commentAutomationRules = { id, tenantId, socialAccountId,
  providerMediaId, keywords: [], matchMode: "exact_normalized",
  templateText, destinationRef, publicAckText: null | string,
  enabled, revision, enabledAt, updatedBy, updatedAt }

commentReplyAttempts = { id, tenantId, socialAccountId,
  connectionGeneration, providerCommentId, providerMediaId,
  commenterScopedId, commentCreatedAt, ruleId, ruleRevision,
  action: "private_reply" | "public_reply", status, expiresAt,
  providerMessageId, attemptCount, errorCode, dispatchedAt,
  acceptedAt, createdAt, updatedAt }
```

Unique index: tenantId + socialAccountId + providerCommentId + action. Enforce it before network calls. A worker crash in sending is reconciled as unknown_outcome, not automatically requeued. Use an atomic account/media/commenter cooldown record so concurrent comments cannot bypass the rule.

Store minimal webhook evidence separately: provider object/account IDs, comment ID, event hash, creation/receipt time and processing result. Retain raw comment text only for the short operational period defined in Section 12. Audit rule revisions and activation; preview evaluates sample text without any provider send call.

Bio configuration and events

```
bioPages = { id, tenantId, published, description,
  showProducts, showReels, fixedLinks: [], themeRef, updatedAt }

bioEvents = { id, tenantId, pageId, eventId, eventType,
  contentId: null | string, pieceId: null | string,
  destinationRef: null | string, sourceTag,
  occurredAt, receivedAt, sessionId: null | string,
  botClassification, contextVersion }
```

Unique index: tenantId + eventId. Query indexes begin with tenantId and occurredAt or receivedAt. Validate event content against the signed public-page context; enforce payload limits, timestamp bounds and sampling/abuse controls. Use the server receipt time for rollups when client time is invalid. No customerId, leadId, orderId, paymentId or revenue field belongs in these contracts.

Independent namespaces

Store first-party bio events separately from platform social metrics. In the dashboard, keep “Instagram reach,” “Bio page views,” and “WhatsApp clicks” visibly distinct. A referrer or UTM may be missing or forwarded; preserve unknown source rather than infer a person’s identity or browsing history.

The existing /m/ design creates unmatched leads. This release must use a new links-module redirect operation, proposed as /go/{linkId}, that logs an outbound event and resolves an allowlisted destination without calling CRM. Comment DM links may carry an opaque campaign/content reference for click reporting, but must not expose a username or comment ID in the URL.

11 HTTP API contract

Authenticated routes derive tenantId from the session. Apply owner/social-manager write permissions, viewer read permissions, CSRF protection where cookie authentication is used, bounded request schemas and cursor pagination. Return RFC 7807-style errors with stable codes. The /hooks and /public routes have separate provider/public validation.

Method and path	Contract
POST /v1/social/instagram/connect	Return authorizationUrl and state expiry.
GET /v1/social/instagram/callback	Validate state, exchange code, redirect to owner result page.
GET /v1/social/accounts	Connection capabilities, coverage, freshness and reconnect state.
DELETE /v1/social/accounts/:id	Stop work, revoke/remove credentials, return deletion job status.
POST /v1/social/accounts/:id/sync	202 + jobId; throttled and idempotent.
GET /v1/social/analytics/overview	accountId, from, to; exact-period metrics, coverage and ready/pending/unavailable query status.
GET /v1/social/analytics/reels	accountId, publishedFrom, publishedTo, sort, cursor; lifetime totals.
GET /v1/social/content/:id/metrics	Current reel metrics and optional observation history.
GET /v1/social/content	Paginated imported media for mapping and rule selection.
PATCH /v1/content-items/:id/pieces	Validate and save same-tenant product mappings.
GET POST PATCH /v1/comment-automation/rules	Read/create; PATCH /:id uses expectedRevision.
POST /v1/comment-automation/rules/:id/preview	Return rendered text and eligibility; no sends.
GET /v1/comment-automation/activity	Cursor, accountId, status; sanitized reply outcomes.
GET PATCH /v1/bio/config	Read/update approved bio settings; PATCH checks revision.
GET /v1/bio/preview	Authenticated preview using the public projection.
POST /v1/public/bio-events	Validate context and dedupe; 202 for accepted event.
GET /go/:linkId	Resolve approved destination, log click and issue 302.
GET POST /hooks/instagram	Challenge verification and signed event ingestion.

Response guarantees

Each metric includes value, unit, scope, period, asOf, lastAttemptAt, availability, freshness and definitionVersion. Account results include actual interval, reporting basis, coverage and queryId if pending. Poll the same overview query for status. Lists include nextCursor. Do not silently omit unavailable metrics or insert financial fields.

Use 409 for ownership/revision conflicts; 422 for invalid mappings/destinations; 429 for local throttles; and 202 for asynchronous work. Provider failures become sanitized reason codes such as RECONNECT_REQUIRED, METRIC_UNAVAILABLE, SEND_WINDOW_EXPIRED and SEND_OUTCOME_UNKNOWN. Never return a raw provider response containing credentials.

12 Security privacy and policy controls

Meta supports the bounded comment/private-reply mechanism, but API support is not a legal certification. Use only official authorization and APIs. Do not collect Instagram passwords, scrape private content, operate browser bots for sending, or create unsolicited follow-up campaigns. Apply the platform rules checked on 13 October 2026 and revalidate them before launch [S4–S7].

Required controls

- Encrypt account credentials at rest; limit decryption to the API/worker role. Redact access tokens, OAuth codes, secrets and message bodies from logs. Enforce HTTPS and an exact OAuth redirect allowlist.
- Bind every resource and job to tenant, social account and connection generation. Test direct-object references, cursor manipulation, forged public events and cross-tenant product mappings.
- Escape captions and comment content in HTML. Limit templates and rendered message length to the current provider contract. Validate every destination; avoid arbitrary server-side URL fetching and thumbnail SSRF.
- Audit account connections, disconnects, permission changes, rule changes and send outcomes. Retain who activated a rule and which revision was used. Provide tenant and platform-wide pause controls.
- Publish privacy and deletion information, support deauthorization/data-deletion requests, and document which party controls the data. Store the minimum required evidence for the requested reply.
- Treat a keyword request as fulfilment of that request only. Do not infer WhatsApp marketing consent, add a commenter to a broadcast audience, or join an Instagram identity to a phone number.

Retention defaults for implementation

Data	Proposed default and deletion behavior
Tokens	Remove on disconnect/revocation; stop new sends and syncs immediately.
Comment text and webhook payload fragments	Delete after 30 days; store only necessary fragments. Do not retain full payloads by default.
Reply audit and dedupe identifiers	90 days, with access restricted to operational roles; purge with account deletion.
Metric observations	365 days while connected, subject to current provider terms and the owner-facing retention policy.
Raw bio events	90 days; daily aggregate reports up to 365 days. Avoid persistent visitor identity.
Account deletion request	Delete linked provider data within seven days as an engineering target, or sooner if an applicable provider/legal deadline requires it; track completion and backup expiry.

These retention periods are product defaults, not statutory requirements. Review them before launch. Indian DPDP provisions have phased commencement; applicable duties depend on the launch date and data use. Obtain a launch-specific review of the privacy notice, processing roles and deletion process [S8]. If later adding WhatsApp marketing, apply its separate opt-in and messaging rules [S7].

13 Delivery checkpoints and acceptance tests

Build sequence

Checkpoint	Evidence required
1 Provider integration spike	A real professional test account connects; owned media imports; core reel/account metric responses are captured and normalized; one keyword private reply succeeds. Record pinned API version and capability matrix.
2 Foundation and public page	Migrations, tenant authorization, connection health, media import, bio page and safe click events work without orders/payments/CRM.
3 Social reporting	Per-reel list/detail, account overview, coverage/freshness, unavailable states and CSV export pass fixture tests.
4 Comment worker	Rules, dry-run preview, webhook validation, send dedupe, cooldown, expiry, pause and unknown-outcome handling pass concurrency tests.
5 Pilot and release	Advanced Access/App Review evidence, privacy/deletion routes, monitoring and controlled pilot with documented sign-off. Do not estimate Meta review time as development time.

Automated acceptance tests

- AUTH: Tenant A cannot access Tenant B accounts, metrics, content, rules or logs; replayed/expired OAuth state fails; a provider account ownership collision returns 409.
- SEND: Duplicate webhook deliveries and simultaneous workers dispatch at most one private reply for a comment. Rule edits cannot bypass the unique key. A send timeout or worker crash after dispatch becomes unknown_outcome and is not blindly retried.
- ELIGIBILITY: Paused rule, disconnected account, expired or pre-activation comment, self-comment, nested reply, unsupported media and missing permission cause no send. A newer connection generation invalidates queued work.
- PREVIEW: Rule preview makes zero send calls. Public acknowledgement is scheduled only after private API acceptance; its failure does not repeat the DM.
- METRICS: Distinguish unavailable from zero; parse both response shapes; preserve corrections; do not sum lifetime snapshots or unique reach. Cache 7/30-day and custom ranges separately; test pending custom queries and exact-interval stale fallback.
- BIO: At 360 px the page is usable; sold products stop appearing as available within ten seconds when catalog integration exists; Instagram failure does not break independent catalog links; telemetry failure does not block navigation.
- SCOPE: No social endpoint, export or UI includes revenue, order, payment, ROAS or sale-conversion fields. No handler invokes CRM lead creation or requires the WhatsApp API.

Operational handover

Deliver migrations/indexes, API schemas, provider fixtures with secrets removed, capability matrix, test results, deployment flags and runbooks for token revocation, rate limiting, delayed metrics, duplicate webhooks, unknown send outcomes and deletion. Monitor sync age, queue delay, provider 429/error rates, reply outcomes and deletion backlog. Alert on failures; do not log personal message contents.

14 Technical examples and source register

Normalized reel metric example

Illustrative application response; the numbers below are test fixtures, not observed shop performance.


```
{
  "contentId": "cnt_example", "scope": "media",
  "period": "lifetime", "metrics": {
    "views": {"value": 12500, "unit": "count",
      "asOf": "2026-10-13T06:00:00Z",
      "lastAttemptAt": "2026-10-13T06:00:00Z",
      "availability": "available", "freshness": "fresh",
      "definitionVersion": "ig_views_v1"},
    "saves": {"value": null, "unit": "count", "asOf": null,
      "lastAttemptAt": "2026-10-13T06:00:00Z",
      "availability": "unavailable", "reason": "provider_empty",
      "freshness": null, "definitionVersion": "ig_saved_v1"}
  }
}
```


The envelope supplies scope and period to each metric. asOf is the observation time of the displayed number; lastAttemptAt records the latest fetch. Empty or transiently unavailable responses do not erase a valid identical-query value: keep that value with stale freshness and a refresh reason. Withdraw it if provider policy or revoked permission requires removal.

Source register

Primary platform references checked on 13 October 2026. The endpoint-specific references take precedence over older examples on overview pages. Engineers must recheck the pinned API version and app permissions during the integration spike.

S1 Instagram insights overview and permissions

S2 Instagram Media Insights metrics and limitations

S3 Instagram Account Insights metrics and parameters

S4 Private replies limits and endpoint

S5 Comment moderation webhooks and replies

S6 Instagram App Review and Advanced Access

S7 WhatsApp Business Messaging Policy for future integration

S8 India DPDP commencement notification

Internal architecture references

L1 docs/architecture/00-master-architecture.md — planned applications, tenant model and outbox.
L2 docs/architecture/01-data-model.md — contentItems, links and existing mixed analytics fields.
L3 docs/architecture/03-plane-b1-shop.md — /bio, /m/ and older revenue analytics. This handoff supersedes the revenue-dependent requirements for this release only.